

MediSecure Telehealth Inc.

Document ID: SEC-POL-024

Version: 1.0

Classification: Internal Use Only

Aligned Frameworks: ISO/IEC 27001:2022 (Controls A.5.15, A.7.10, A.8.12, A.8.20) | ITIL v4 (Change & Event Management)

1. PURPOSE

This policy defines the mandatory technical restrictions and monitoring requirements to protect MediSecure's proprietary source code, intellectual property (IP), and sensitive patient data from unauthorized modification, exfiltration, or theft by internal or external actors.

2. SCOPE

This policy applies to all employees, contractors, and third-party vendors utilizing MediSecure corporate endpoints, networks, and cloud infrastructure.

3. POLICY STATEMENTS

3.1 Device & Endpoint Security (ISO 27001 A.7.10)

- **USB & Storage Restriction:** All corporate endpoints must run Data Loss Prevention (DLP) software that blocks the writing of data to unapproved external storage media (USBs, external hard drives, SD cards) by default.
- **Exceptions:** Temporary access to write to removable media requires an approved **ITIL Change Ticket** and justification from a Department Head.

3.2 Access Control & Code Repositories (ISO 27001 A.5.15)

- **Principle of Least Privilege:** Access to production source code repositories (e.g., GitHub Enterprise) must be restricted strictly to active project personnel.
- **Dual Authorization:** Any action to clone, download, or export an entire repository must be routed through a peer-review and manager-approval pipeline.

3.3 Network Egress & Web Filtering (ISO 27001 A.8.20 & A.8.23)

- **SSL/TLS Decryption:** To inspect outbound data, all corporate network traffic bypassing the firewall must undergo secure decryption and deep packet inspection.
- **Uncategorized Domain Blocking:** Access to newly created domains (less than 30 days old) or "Uncategorized/Unknown" websites via corporate devices is blocked automatically.

3.4 Content-Aware Data Loss Prevention (ISO 27001 A.8.12)

- **Exfiltration Blocking:** The corporate network must monitor and analyze all outbound HTTP/HTTPS payloads.
 - **Data Whitelisting:** File transfers are blocked by default **unless** the destination matches the company's official corporate whitelist (e.g., corporate AWS buckets, approved corporate GitHub).
 - **Code Signature Detection:** Any attempt to upload text patterns resembling programming code, database schemas, or patient records to an unapproved external destination must be blocked automatically.
-

4. MONITORING & INCIDENT TRIGGER (ITIL Practice)

The Security Operations Center (SOC) must maintain active SIEM alert rules for anomalous data movement. The following events will trigger an immediate **High-Severity Incident (ITIL)**:

1. Detection of command-line exfiltration tools (e.g., unauthorized use of `curl`, `wget`, `scp`) targeting external IP addresses.
2. Any single endpoint uploading more than 50MB of data to an unwhitelisted external destination within a 1-hour window.
3. Sudden high-volume file modifications or downloads outside of standard local working hours.

5. ENFORCEMENT & COMPLIANCE

Any employee found to have violated this policy, or to have intentionally bypassed these technical controls (e.g., attempting to disable DLP software), will face immediate disciplinary action up to and including termination of employment and legal prosecution.